

## Lab 05 – Shodan Reconnaissance – Solutions

Industrial Security (Bachelor)

• Maps to Section 05

• 30 min

LAB 05

### 🎯 Goal

Lecturer / TA reference: sample Shodan queries, expected banner shapes, ethical framing, common student mistakes, and grading rubric. All examples are illustrative; no real exposed assets are named.

### ✓ Sample queries and what they typically surface

- `port:502` – Modbus/TCP. Tens of thousands of hits worldwide; banner usually shows function code 43 (Read Device Identification) replies with vendor/product strings.
- `port:47808` – BACnet/IP. Surfaces building-automation controllers (chillers, AHUs, lighting). Banner includes **Instance** ID, vendor name, model.
- `product:siemens` – Siemens S7 family on TCP/102. Banner exposes module order number (e.g. 6ES7 ...) and firmware revision.
- `tag:industrial` – Shodan’s own ICS tag, a broad catch-all across protocols.
- `org:"<utility name>"` – Pivots from an ASN/organisation string to all devices in their address space.
- `country:DE port:502` – Narrows Modbus exposure to Germany; useful for the deliverable.
- `"Unitronics" port:20256` – Vision/Samba PLCs (the family CISA flagged in late-2023 water-sector attacks).

### ✓ Illustrative finding format (fictional)

*Use this shape; do not record real IPs or org names in the report.*

- **Country / ASN:** DE / ASXXXXXX (regional ISP, business DSL).
- **Banner:** Modbus/TCP, slave id 1, vendor “Schneider Electric”, product “Modicon M221”, firmware 1.x.
- **Plausible function:** pump/valve controller – small water-works or district-heating substation, judging by the ASN footprint and DNS suffix pattern.
- **Why exposed:** most likely a 4G/DSL router with port-forwarding for an integrator’s remote-maintenance laptop; no VPN; static IP cheaper than a managed jump host.

### ✓ Why these devices end up on the open Internet

- **Vendor remote-access shortcuts.** “Forward TCP/102 to the PLC so we can dial in.” Documented in many commissioning guides.
- **Integrator convenience.** “We put it behind a static IP for the integrator” – avoids the cost of a VPN concentrator and per-site credentials.
- **4G/LTE routers with public APNs.** Many cellular gateways expose the LAN directly; default firewall is permissive.
- **Legacy migration.** A site that used to be on a private leased line gets “upgraded” to commodity Internet with the same flat addressing.

- **Embedded web servers nobody knew were on.** Vendor firmware ships HTTP/SNMP/FTP enabled by default.

### ✓ Ethical and legal framing (read-only contract)

Students must **not** connect, log in, fingerprint, port-scan, or otherwise interact with anything they discover. Browsing the Shodan-cached banner is fine; sending a single TCP packet to the target is not. In Germany, **§202c StGB** (“Vorbereiten des Ausspähens und Abfangens von Daten”) and **§202a/b StGB** can criminalise unauthorised probing *even without exploitation or data exfiltration*. Comparable rules exist under the UK Computer Misuse Act 1990 and the US CFAA. If a student believes they have found a genuinely exposed safety-relevant asset, the correct action is to report it – in Germany to **CERT-Bund** ([certbund@bsi.bund.de](mailto:certbund@bsi.bund.de)) with the IP, port, observed banner, and timestamp; not to “just check if it’s really vulnerable.”

### ✓ Hand-in expectations

A one-page PDF containing: (i) three Shodan queries the student actually ran, (ii) the approximate result count Shodan reported at that moment, (iii) a one-paragraph reflection on whether the scale or the device families were surprising, and (iv) answers to the three responsibility/remedy questions in the lab sheet. No IPs, hostnames, or organisation names.

### ✓ Common student mistakes to flag

- Copy-pasting a discovered IP into `nmap`, `curl`, or a Modbus client. This crosses from passive reconnaissance into unauthorised access; fail the deliverable and remind them of §202c StGB.
- Mistaking a honeypot for a real PLC. Conpot and similar honeypots leak telltale signatures: unrealistically rich device identification fields, vendor strings that do not match the firmware revision, identical banners across many ASNs, and Shodan’s own **honeypot score** (where shown).
- Equating “high CVSS” with “easy to exploit”. CVSS is severity-if-exploited; reachability, authentication, network segmentation, and patch level often make a 9.8 unreachable in practice and a 6.5 trivially abusable.
- Pasting real IPs/hostnames into the reflection.
- Searching for the lecturer’s home country only – broaden to a second jurisdiction for contrast.

### ⚖️ Grading rubric

- **Three valid queries with counts (3 pt).** Queries syntactically correct, counts plausible, no interaction with targets.
- **Reflection paragraph (3 pt).** Shows the student understood scale, not just numbers; identifies at least one structural cause (vendor default, integrator convenience, 4G modem, legacy migration).
- **Responsibility / remedy answers (3 pt).** Names vendor, integrator, asset owner, ISP *and* a regulator/CERT role; concrete first-day action for the asset owner (disconnect, VPN, change creds, notify CERT).
- **Ethics compliance (1 pt, gating).** Zero IPs / hostnames / org names disclosed; no evidence of active probing. Violation  $\Rightarrow$  0 overall.

**Total: 10 pt.**